ÉTUDE DE CAS — STRIPE

LIVRABLE 6

Plan de sécurité et de conformité

Certification RNCP 41993 – Adrien COSSON
Bloc 2 - Concevoir et déployer l'infrastructure de données et de calcul pour l'IA

Stripe traite chaque jour un très grand nombre de paiements et manipule des données sensibles : numéros de carte, données personnelles des clients et données financières des marchands. Ce plan décrit les mesures mises en place pour protéger ces données dans toute l'architecture et pour respecter les réglementations des différents pays dans lesquels Stripe est déployé. Il répond aux six exigences du sujet :

- Chiffrement.
- Contrôle d'accès.
- Journalisation des audits.
- Conformité réglementaire.
- Surveillance en temps réel.
- Suivi automatisé de la conformité.

1. Chiffrement des données

- **Au repos :** toutes les données stockées sont chiffrées : Aurora PostgreSQL, DocumentDB, Redis, Redshift, ainsi que les fichiers du Data Lake S3 et de Glacier. Les clés de chiffrement sont gérées par AWS KMS, avec un renouvellement régulier.
- **En transit :** tous les échanges entre les services (API, Debezium, Kafka, bases de données, Airflow) passent par des connexions chiffrées en TLS.
- **Tokenisation des cartes :** le numéro de carte n'est jamais stocké dans l'architecture. Il est remplacé par un jeton/token (payment_token) et seuls les 4 derniers chiffres sont conservés pour l'affichage. Les bases et le Data Lake ne contiennent donc aucun numéro de carte, ce qui réduit fortement le périmètre soumis à PCI-DSS.
- **Pseudonymisation :** les données utilisées pour l'analyse et le Machine Learning ne contiennent pas de nom, d'email ni de téléphone. Les clients y sont identifiés uniquement par leur identifiant, comme le montre la table dim_customer du livrable 3.

2. Contrôle d'accès par rôle

Les accès sont gérés avec AWS IAM, selon le principe du moindre privilège : chaque rôle n'accède qu'aux données dont il a besoin.

Rôle	Accès autorisés
Service de paiement	Écriture dans Aurora PostgreSQL
Analyste / BI	Lecture de Redshift uniquement (données sans identité)
Data scientist	Lecture des données préparées du Data Lake et de MLflow
Équipe fraude	Lecture des alertes et des transactions signalées
Support client	Lecture limitée des fiches clients dans l'OLTP
Administrateur	Gestion de l'infrastructure, avec authentification forte (MFA)

Les bases de données sont placées dans des sous-réseaux isolés, sans accès depuis Internet (segmentation du réseau présentée au livrable 1, section 5). Les mots de passe et les clés d'accès sont stockés dans AWS Secrets Manager, jamais dans le code. Les droits sont revus régulièrement.

3. Journalisation des audits

Deux niveaux de journalisation sont mis en place :

- **La table audit_log de l'OLTP** (livrable 2) enregistre les actions sur les données : qui a lu, créé, modifié ou supprimé quelle ligne, et quand. Le champ customer_id permet de retrouver rapidement toutes les actions concernant un client.
- **AWS CloudTrail** enregistre toutes les actions réalisées sur l'infrastructure AWS : création de ressources, modification des droits, accès aux clés KMS…

Les journaux sont conservés dans un espace S3 protégé contre la modification et la suppression, afin de pouvoir servir de preuve lors d'un audit. La table audit_log est aussi chargée dans Redshift (table fact_audit, livrable 3), ce qui permet de produire des rapports sur les accès aux données (livrable 8, requête 16).

4. Conformité réglementaire

- **PCI-DSS (Internationale) :** c'est la norme de sécurité imposée par les réseaux de cartes bancaires (Visa, Mastercard…) pour protéger les données de carte. Elle est respectée grâce à la tokenisation, au chiffrement, au contrôle des accès et à la journalisation.
- **RGPD (Union européenne) :** les données des clients européens sont stockées dans une région AWS située dans l'UE et seules les données nécessaires sont collectées (minimisation). Un client peut demander l'accès à ses données ou leur suppression ; les données de paiement, que Stripe doit conserver pour des raisons légales, sont alors anonymisées plutôt que supprimées. En cas de fuite de données, l'autorité de contrôle (la CNIL en France) est prévenue sous 72 heures.
- **CCPA (Californie) :** cette loi donne aux clients californiens des droits comparables à ceux du RGPD : savoir quelles données sont collectées sur eux, demander leur suppression et refuser que leurs données soient vendues ou partagées.
- **Durées de conservation :** chaque type de données a une durée de conservation définie, présentée dans le tableau ci-dessous. Les suppressions sont automatiques (index TTL dans DocumentDB, règles de cycle de vie dans S3).

Données	Conservation en base	Ensuite
Transactions (OLTP)	24 mois dans Aurora PostgreSQL	Data Lake puis S3 Glacier, 10 ans au total (durée légale de conservation des pièces comptables en France). Données personnelles anonymisées sur demande
Journaux d'audit (audit_log, CloudTrail)	Au moins 1 an, dont 3 mois consultables immédiatement (exigence PCI-DSS)	Archivage dans S3 Glacier
Sessions et clickstream	13 mois dans DocumentDB	Suppression (même durée dans le Data Lake)
Logs techniques	90 jours dans DocumentDB	1 an dans le Data Lake, puis suppression
Prédictions du modèle	13 mois dans DocumentDB	Data Lake, pour le suivi et le réentraînement des modèles
Avis clients	Tant que le compte du client est actif	Suppression ou anonymisation sur demande

5. Surveillance des failles en temps réel

- **Amazon GuardDuty** analyse en continu l'activité du compte AWS et détecte les comportements suspects : connexion depuis un pays inhabituel, utilisation anormale d'une clé d'accès, tentative d'accès à des données sensibles…
- **Amazon CloudWatch** surveille les métriques et les journaux (erreurs, pics d'accès, échecs de connexion) et déclenche une alerte vers l'équipe sécurité dès qu'un seuil est dépassé.

6. Suivi automatisé de la conformité

- **AWS Config** vérifie en continu que les ressources respectent les règles définies : chiffrement activé sur chaque base et chaque espace S3, aucune base accessible depuis Internet, journalisation activée…
- **AWS Security Hub** regroupe les résultats de ces contrôles et ceux de GuardDuty dans un tableau de bord unique. Il compare aussi l'architecture à des référentiels de sécurité, dont PCI-DSS, ce qui permet de produire automatiquement des rapports de conformité.

Ce suivi automatique permet de détecter un écart dès qu'il apparaît, au lieu de le découvrir lors d'un audit manuel.

7. Synthèse

Exigence du sujet	Mesure	Outils
Chiffrement	Données chiffrées au repos et en transit, tokenisation des cartes	AWS KMS, TLS
Contrôle d'accès par rôle	Moindre privilège, MFA, sous-réseaux privés	AWS IAM, Secrets Manager
Journalisation des audits	Traçabilité des actions sur les données et sur l'infrastructure	Table audit_log, AWS CloudTrail
Conformité selon les juridictions	Données UE stockées dans l'UE, minimisation, durées de conservation, anonymisation sur demande d'effacement, notification des fuites	Régions AWS, tokenisation, anonymisation
Surveillance des failles en temps réel	Détection des comportements suspects et des tentatives d'accès non autorisé, avec alertes	Amazon GuardDuty, CloudWatch
Contrôles et rapports de conformité automatisés	Vérification continue des règles, tableau de bord et rapports (dont les rapports d'accès issus de fact_audit)	AWS Config, Security Hub